

RBAC Module - Test Cases (Week 4)

#	Test Case	Steps	Expected Result	Actual Result	Status
1	Admin accesses GET /api/users	Call with valid Admin token	200 OK, list of users returned	200 OK, user list returned correctly	Pass
2	Staff accesses GET /api/users	Call with valid Staff token	403 Forbidden	403 Forbidden	Pass
3	No token accesses GET /api/users	Call with no Authorization header	401 Unauthorized	401 Unauthorized	Pass
4	Admin promotes a Staff user to Admin	PUT /api/users/{id}/role with role=Admin using Admin token	200 OK, role updated to Admin	200 OK, role updated and reflected in UI	Pass
5	Staff attempts to promote a user	Same call as above using Staff token	403 Forbidden	403 Forbidden	Pass
6	Admin deactivates a patient	PUT /api/patients/{id}/deactivate using Admin token	200 OK, patient marked inactive	200 OK, patient deactivated successfully	Pass
7	Staff attempts to deactivate a patient	Same call as above using Staff token	403 Forbidden, UI shows Admin access required message	403 Forbidden, clear permission message shown	Pass
8	Admin deactivates a doctor	PUT /api/doctors/{id}/deactivate using Admin token	200 OK, doctor marked inactive	200 OK, doctor deactivated successfully	Pass
9	Staff attempts to deactivate a doctor	Same call as above using Staff token	403 Forbidden, UI shows Admin access required message	403 Forbidden, clear permission message shown	Pass
10	Navbar and direct URL access as Staff	Log in as Staff; check navbar for User Management/Dashboard links, then manually navigate to /User and /Dashboard	Links hidden from navbar; direct URL access shows permission required message, no data leaked	Links correctly hidden; direct access blocked with clear message on both pages	Pass